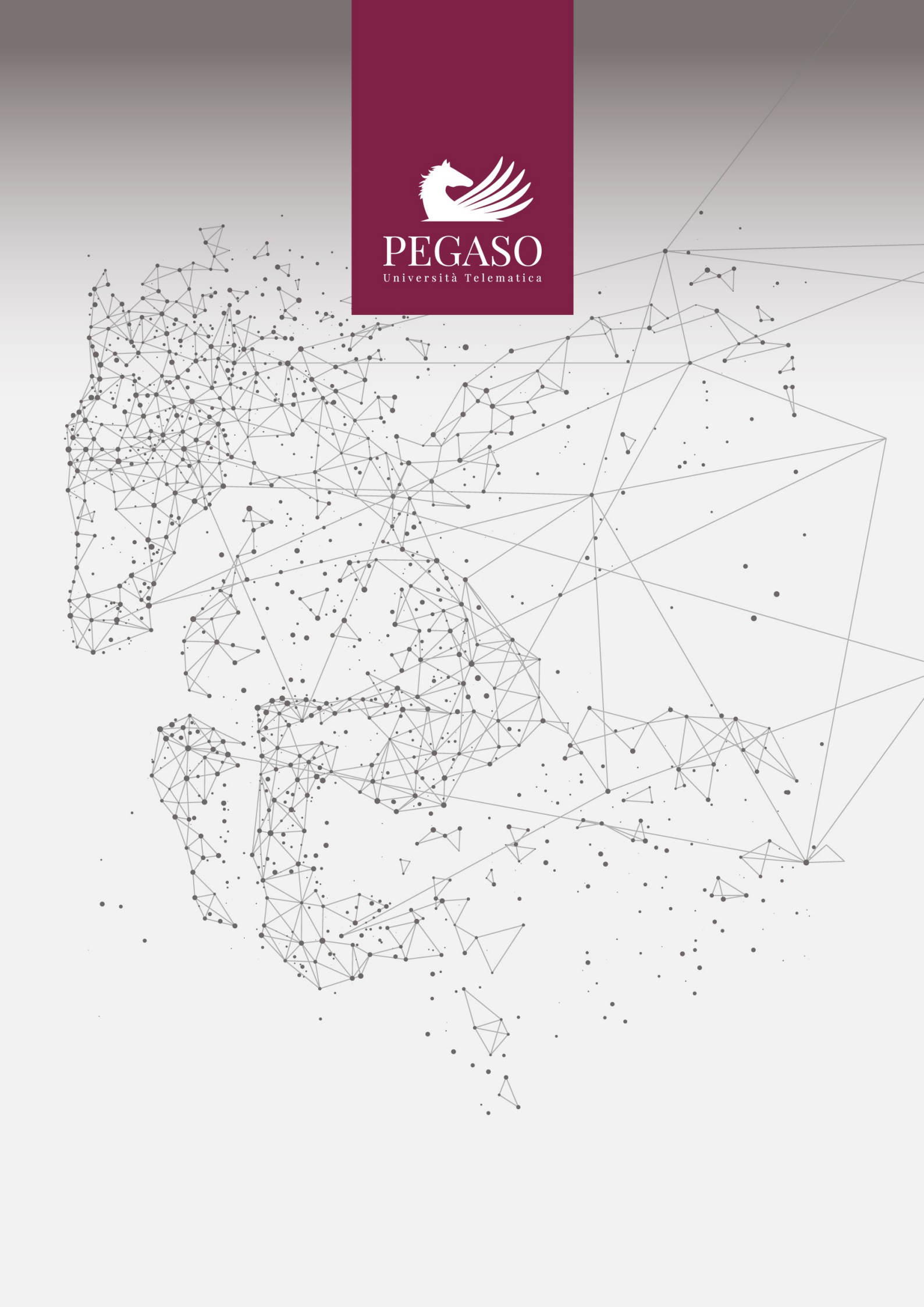

PEGASO
Università Telematica

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1 IL PROTOCOLLO TLS: INTRODUZIONE 3

2 IL PROTOCOLLO TLS: LA FUNZIONE PSEUDO-RANDOM 5

3 IL PROTOCOLLO HTTPS 8

BIBLIOGRAFIA 10

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1 Il protocollo TLS: introduzione

Il **protocollo TLS (Transport Layer Security)** è l'evoluzione di SSL in una versione standard per Internet. SSL si è sostanzialmente evoluto attraverso tre versioni fino ad arrivare ad SSLv3. La prima versione di TLS v1.0 (RFC 2246) è molto simile a SSLv3 sebbene vi siano alcune differenze interessanti (ora ne vediamo alcune!). TLS si è poi a sua volta aggiornato in TLS v1.1 (RFC4346) e TLS v1.2 (RFC5246)

Il protocollo TLS costituisce uno dei servizi di sicurezza più utilizzati, infatti la quasi totalità dei browser hanno a bordo TLS e la maggior parte dei server web implementano le funzionalità del protocollo.

In maniera analoga a SSL, da cui TLS deriva, esso è costituito da una serie di protocolli che si appoggiano sul livello TCP.

Esistono comunque delle differenze tra SSLv3 e TLSv1.0 di cui le principali sono indicate qui di seguito:

- l'intestazione *SSL Record* cambia nel formato dei numeri di versione
- la tipologia di calcolo MAC e l'algoritmo utilizzato sono diversi (SSLv3 usa una versione iniziale di HMAC mentre TLSv1.0 usa proprio HMAC)
- TLSv1.0 usa una funzione pseudocasuale (chiamata *PRF*) per espandere i valori segreti
- TLS supporta dei codici di allarme addizionali
- le tipologie di cifrature supportate sono differenti
- differenti sono i tipi di certificati adoperati e le negoziazioni degli stessi
- padding: non si fa soltanto fino alla quantità minima di multipli interi della dimensione del blocco ma si può usare qualsiasi multiplo; si introduce così una

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

casualità nella lunghezza dei messaggi scambiati che quindi rende più complessi gli attacchi basati sull'analisi della lunghezza.

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

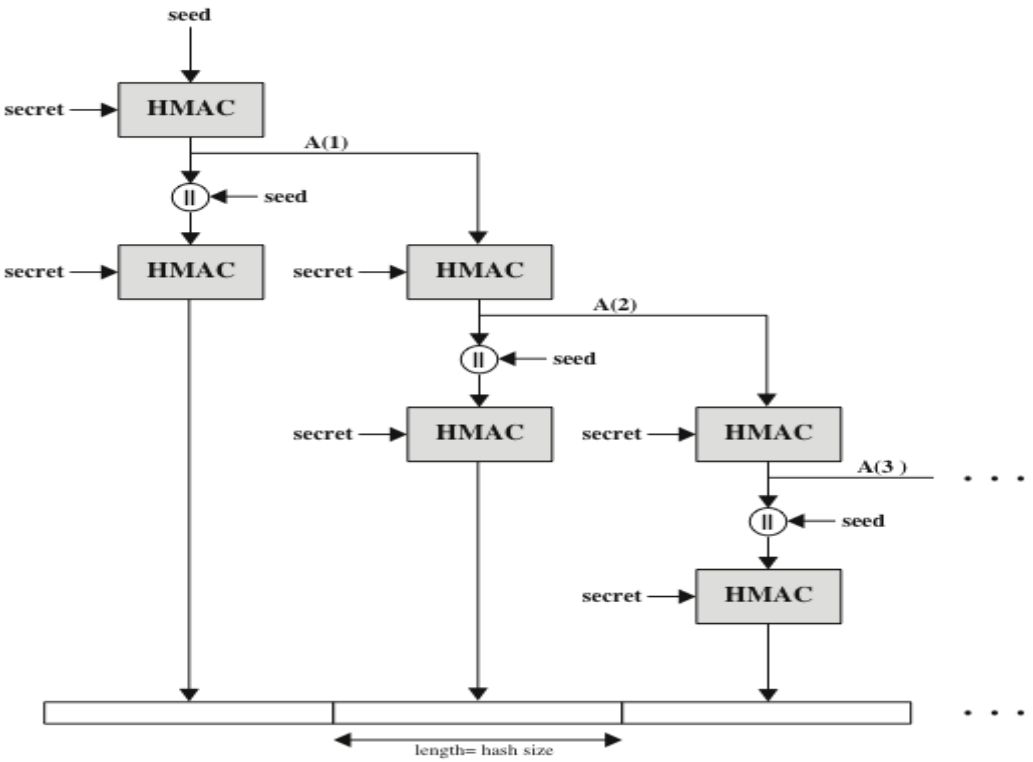
2 Il protocollo TLS: la funzione pseudo-random

Il protocollo TLS usa una funzione pseudocasuale (chiamata *PRF - Pseudo Random Function*) per espandere i valori segreti in blocchi di dati per la generazione o la convalida della chiave

L'obiettivo è utilizzare un valore segreto condiviso relativamente compatto per generare lunghi blocchi di dati sicuri. La PRF è basata su HMAC e prende in ingresso due valori:

- *il valore di seed*
- *il valore segreto*

Nella figura seguente è rappresentato il funzionamento della PRF.



Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

In pratica la PRF esegue la seguente operazione:

PRF(secret, seed)=

HMAC(secret, A(1) || seed) ||

HMAC(secret, A(2) || seed) ||

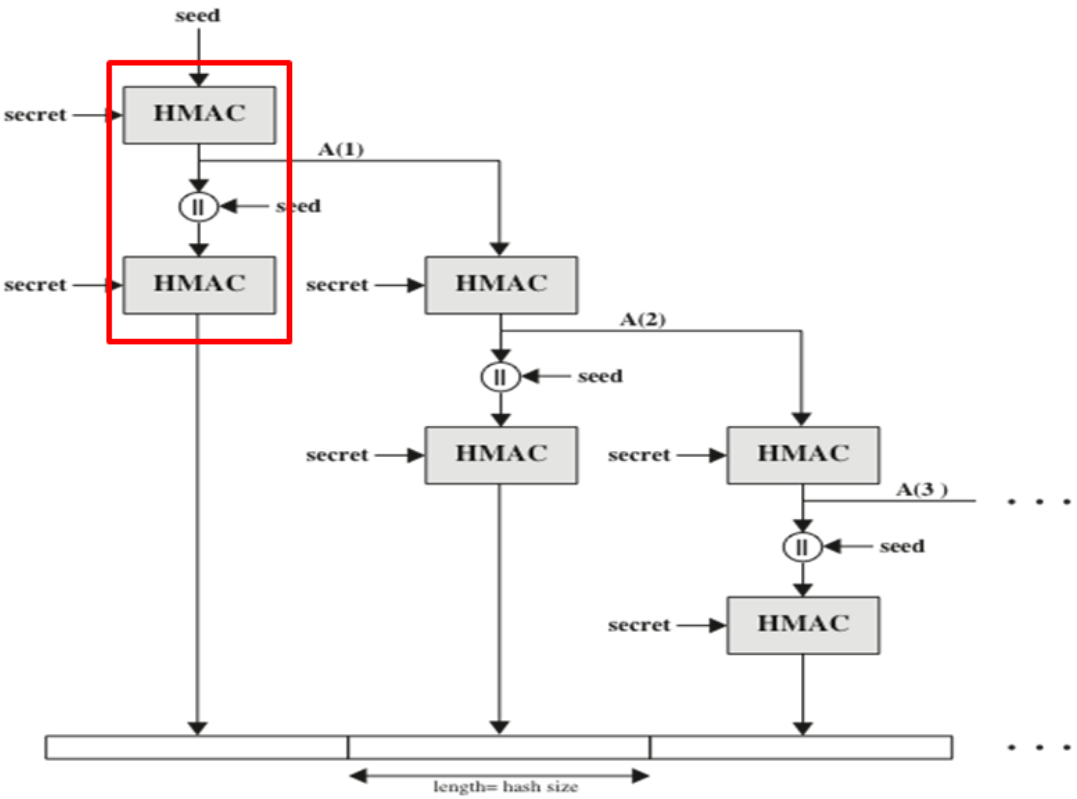
HMAC(secret, A(3) || seed) ||

……..

dove si ha che:

A(0) = seed

A(i) = HMAC(secret, A(i-1))



Per comprendere meglio il singolo funzionamento si consideri il blocco in rosso nella figura qui sopra. In questo caso il valore di output è pari a:

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

HMAC(secret, A(1) || seed)

che va a costituire il primo elemento nell'array di uscita. Analogamente vengono prodotti gli altri elementi nelle successive iterazioni.

La PRF può essere iterata più volte fino ad ottenere la quantità di dati desiderati; i byte generati ed eventualmente in eccesso vengono scartati.

La PRF utilizza l'algoritmo HMAC con SHA-1 (digest di 20 byte) o MD5 (digest di 16 byte) come funzioni hash di base. Ciascuna esecuzione della PRF prevede due esecuzioni di HMAC e conseguentemente due esecuzioni dell'algoritmo di hash sottostante. Per aumentare la sicurezza della PRF si possono anche usare entrambi gli algoritmi hash in maniera combinata

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3 Il protocollo HTTPS

Il principale esempio di uso di SSL (TLS) è il **protocollo HTTPS (HyperText Transfer Protocol over Secure Socket Layer)** che identifica la combinazione di HTTP e SSL per implementare una comunicazione sicura tra un browser e un server web

Le connessioni HTTPS erano inizialmente usate per i pagamenti effettuati su web, per la posta elettronica e per le transazioni sensibili; successivamente si è cominciato ad usare HTTPS per proteggere l'autenticità delle pagine web e per mantenere private le comunicazioni

Quando il protocollo HTTPS viene eseguito nel browser si vede che l'indirizzo URL da *http://* diventa *https://* ed è individuato dall'icona con il lucchetto



Non ci sono fondamentali differenze fra HTTP su SSL o su TLS (RFC 2818), entrambe vengono comunemente indicate come HTTPS

La porta utilizzata generalmente è la 443, quella per HTTP è invece la porta 80

Quando si utilizza il protocollo HTTPS vengono cifrati i seguenti elementi della comunicazione:

- URL della risorsa richiesta
- i contenuti della risorsa
- i contenuti delle form del browser
- i cookies inviati in entrambe le direzioni (da browser verso il server, da server verso il browser)
- i contenuti dell'header HTTP

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Nell'avvio di una connessione HTTPS il client si connette al server sulla porta appropriata e poi invia un *TLS ClientHello* per iniziare la fase del TLS handshake. Quando il TLS handshake è finito, allora il client può inoltrare la prima richiesta di tipo http; tutti i dati HTTP sono inviati come dati dell'applicazione TLS.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: Capitoli 17.
- "Cryptography and Network Security", 7/ed, William Stallings, Pearson.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).